Project Overview: Quantum-Safe Certificate Authority for Secure Certificate Management

immediate

Abstract

Nowadays, due to the rise of quantum threats, the use of classical certificates is becoming risky, as attackers could potentially forge certificates and impersonate any website - completely compromising HTTPS security. This is because today's WebPKI relies on classical encryption algorithms such as RSA (e.g., RSA-2048) ECC (e.g., ECDSA P-256) whose security hardness depends on the problem of integer factorization (RSA) and elliptic curve discrete log (ECC), both of which are infeasible to solve using classical computation. Therefore, we propose to develop a quantum-safe private Certificate Authority (CA), which signs the certificate using post-quantum cryptography (PQC) to verify the ownership of public keys used in secure communications (e.g., HTTPS, email, VPNs). Our proposed architecture follows a standard hierarchical trust model, consisting of a Root Certificate Authority (Root CA), an Intermediate Certificate Authorities (ICA), and an end-user/server that wants the certificate from CA. The CA maintains a database for managing certificate-related information. While we assume the CA to be fully trusted in our model, the architecture can be extended to operate in a semi-honest environment by leveraging secure multi-party computation techniques to process sensitive data in a quantum-resilient manner. In this framework, during communication between parties, an AES session key is securely established using the NIST-standardized post-quantum key encapsulation mechanism, CRYSTALS-Kyber. After the session key is established, entity authentication and certificate signing are performed using a post-quantum signature algorithm such as CRYSTALS-Dilithium. To enhance security, the system incorporates an anomaly detection module that monitors suspicious activities during certificate issuance and flags abnormal behavior. Identified entities are added to a Certificate Revocation List (CRL), which is distributed by a CRL responder and checked by both clients and servers during communication to prevent interactions with revoked entities.

1. WHAT WE HAVE BUILT

1.1. Complete Certificate Lifecycle Management

The system supports the full lifecycle of digital certificates:

- Secure CRYSTAL-Dilithium key generation
- PQC-based Certificate Signing Request (CSR) creation
- Certificate validation and issuance of classical, hybrid (classical + PQC) and pure PQC certificates based on user requirements.
- Deployment for secure communication through post-quantum key encapsulation mechanism CRYSTALS - Kyber.

We are not just generating certificates—we are managing the **entire pipeline from request to trust establishment**.

1.2. Areas of Application

In today's rapidly advancing digital age, cloud computing has become an essential part of everyday life. It supports a wide range of sectors, including banking, insurance, e-commerce, social media, healthcare, research, and defense. Cloud platforms provide several types of services that enable data storage, computation, application hosting, and secure communication, making them highly scalable and widely adopted across industries.

As reliance on cloud technologies increases, so do the associated risks. If sensitive data is compromised, financial assets are stolen, or information is altered without authorization, it can severely damage organizational reputation and, in critical sectors like defense and government, even threaten national security.

Cloud servers today store highly sensitive data across multiple domains. In the financial sector, this includes transaction records and customer details; in healthcare, patient records and medical histories; in the research domain, intellectual property, experimental data, and unpublished findings; and in defense and government sectors, classified communications and strategic information. Any unauthorized access, leakage, or tampering of such data can lead to severe consequences, including financial loss, privacy violations, intellectual property theft, or national security risks.

Traditional cryptographic systems, such as RSA and ECC-based Certificate Authorities (CA), rely on mathematical problems that are difficult for classical computers to solve. However, in the post-quantum era, these systems become vulnerable due to quantum algorithms like Shor's algorithm, which can break such encryption efficiently.

To address this, Post-Quantum Cryptography (PQC) and Quantum-Safe Certificate Authorities (QCA) have emerged as crucial solutions. PQC is considered more secure than classical cryptography because it is based on mathematical problems that are resistant to both classical and quantum attacks. Quantum-Safe CAs further strengthen the security framework by ensuring that digital certificates, authentication mechanisms, and communication channels remain trustworthy even in the presence of quantum computing capabilities.

In the post-quantum era, adopting PQC and QCA is essential to ensure long-term data protection, secure communication, and resilience against evolving cyber threats across all critical sectors.

1.3. System Initialization (Trust Setup) (Industry-Standard Design)

We first establish a **hierarchical trust chain**:

- Root CA (offline, highly secure)
- Intermediate CA (handles certificate issuance)

Root CA :

- Generates classical + CRYSTALS-Dilithium keys
- Signs the Intermediate CA certificate
- Distribute Root public key to users to establish trust anchor.
- Intermediate CA signs Server's classical certificates (used in applications)
- Client trust via OS-level certificate store

This mirrors how trusted providers like public CAs operate, ensuring that the system follows **proven and scalable security principles**.

1.4. Secure Web-Based Certificate Issuance Platform

User connects to the system via web interface

- A secure channel is established using PQC key exchange: CRYSTALS-Kyber (ML-KEM-768) is used
- User Register and authenticate

- Accesses certificate request portal
- Before request a certificate, user generates cryptographic keys: PQC keys (Dilithium), and classical keys
- User selects certificate type: Classical / Hybrid / Pure PQC
- User then creates and submits CSR (Certificate Signing Request) signed using Dilithium

This provides a **user-friendly interface over a complex cryptographic backend**, making the system practical and accessible.

1.5. Domain Ownership Verification (DCV Simulation)

To ensure that certificates are issued only to legitimate owners, we implemented a **Domain Control Validation (DCV)** mechanism.

- The system verifies domain ownership before issuing certificates at registration phase.
- A simulated validation server demonstrates how real-world DNS or HTTP validation works
- Initially, registration information is stored as pending. It is approved after successful validation.
- User able to login and access the certificate request portal.

This ensures that **security is enforced at the identity level**, not just at the encryption level.

1.6. Certificate Signing Process

User enters into certificate access portal

- selects type of certificate: classical/hybrid (classical+PQC)/Pure PQC certificate.
- Sends CSR using CRYSTALS-Dilithium.
- CSR integrity is verified by Intermediate CA
- Intermediate CA issues certificate according to user (classical/hybrid (classical+PQC)/Pure PQC certificate)
- Issued certificates are stored securely in Intermediate CA's database.
- User downloads the certificates on demand.
- Our intermediate CA-issued certificate sizes: Classical (~644 bytes), Hybrid (~5 KB), PQC (~7 KB)

1.7. TLS-Enabled Secure Communication

The issued certificates are actively used in a **TLS-enabled server**, enabling:

- Encrypted client-server communication
- Communication uses Kyber-based key encapsulation to ensure encryption, authentication and data integrity
- Browser-based secure access
- Full trust validation without warnings

This demonstrates that the system is not theoretical—it is **fully functional and operational**.

1.8. Administrative Control and Monitoring

An administrative panel allows controlled oversight of the system:

- Monitoring certificate requests
- Managing users
- Validating domain ownership
- Controlling certificate issuance

This introduces **governance and operational control**, which are essential for real deployments.

1.9. Continuous Monitoring & Anomaly Detection

The system applies the following revocation policies:

- If User Id and Password are compromised (DCV failed multiple times). (Authentication log)
- Certificate presented from unexpected IP/location. (TLS handshake metadata, IP address, VPN Gateway Logs).
- Certificate hash mismatch (tampering). (CA Certificate Database)
- Key Usage / Extended Key Usage (EKU) Violation.
- Certificate Used After Expiry or Before Validity Period.
- Sudden Spike in Authentication Attempts With the Same Certificate
- Certificate Public Key Appears in More Than One Certificate (Key Reuse)
- Certificate Signing Request (CSR) Irregularities.

If system detects or monitors suspicious activities during certificate issuance and flags abnormal behavior, that user's certificate will be added to a Certificate Revocation List (CRL), which is distributed by a CRL responder periodically to the users.

1.10. Support for Modern Cryptographic Standards

The system supports:

- X.509 certificate format (industry standard)
- TLS 1.2 and TLS 1.3 protocols
- Multiple certificate formats (including hybrid and post-quantum representations)

This ensures the solution is **future-ready and adaptable** to evolving security requirements.

2. KEY STRENGTHS OF THE SOLUTION

- **End-to-End Implementation**: Covers the entire PKI workflow, not just isolated components
- **Realistic Architecture**: Closely follows industry-standard certificate authority designs
- **Operational Demonstration**: Fully working system with live certificate issuance and validation
- **Modular Design**: Each component (Root CA, Intermediate CA, server, client) is independently manageable
- **Extensible Framework**: Can be enhanced with production-grade features such as hardware security modules or revocation systems

3. CURRENT SCOPE AND POSITIONING

We have designed a **functional prototype and demonstration platform**. It effectively showcases:

- How secure certificate ecosystems operate
- How trust is established and maintained
- How users and systems interact within a PKI environment

While it already delivers a complete working model, it is intentionally lightweight and flexible, making it ideal for:

- Demonstrations and client presentations
- Research and experimentation
- Rapid prototyping of secure communication systems

4. FUTURE READINESS

The system is built with a forward-looking design and can be extended to include:

- Hardware-based key protection (HSM integration)
- Certificate revocation mechanisms (CRL/OCSP)
- Real-world domain validation (DNS/ACME integration)
- Enhanced security controls and scalability

CONFIDENTIAL
Amlan, Aakashi, Janusree

5. CONCLUSION

Our team has successfully developed a **comprehensive PKI solution that bridges theory and practice**. It demonstrates not only how digital certificates are created, but how they are trusted, validated, and used in real secure communications.

6. SUMMARY

We have developed a fully functional Public Key Infrastructure (PKI) system that demonstrates how secure digital certificates are created, validated, and used to enable trusted communication between systems. The solution follows a standard hierarchical trust model, consisting of a Root Certificate Authority (Root CA), Intermediate Certificate Authorities, and end-user/server certificates. This structure mirrors real-world implementations used by global certificate providers, ensuring both scalability and security. Our system supports the complete certificate lifecycle, including key generation, Certificate Signing Request (CSR) handling, domain ownership verification, and certificate issuance. A web-based interface allows users to easily register, request certificates, and securely interact with the system. To ensure authenticity, we implemented a Domain Control Validation (DCV) mechanism, verifying that certificates are issued only to legitimate domain owners. The issued certificates are actively deployed in a TLS-enabled server, enabling encrypted communication and successful trust validation on the client side. Additionally, an administrative control layer provides oversight of certificate requests, user activity, and validation processes, ensuring structured governance of the system. Overall, this project delivers a practical, end-to-end implementation of a certificate authority ecosystem, combining security, usability, and modular design. It serves as both a demonstration platform and a strong foundation for extending into a production-grade secure communication infrastructure.

CONFIDENTIAL
Amlan, Aakashjit, Tanusree